



RAPPORT DE RISQUE SUR MEDISCOPE

Éditeur lyonnais

(créé en 2019) qui développe

une plateforme d'imagerie

médicale assistée par IA.

Réalisé par:

VOUBOU MOUDODOU Guewen Klett

Année 2026



SOMMAIRE

INTRODUCTION	3
Atelier 1 : Socle de sécurité	4
1- Cartographie des valeurs métiers et Évaluation CID	4
2- Événements redoutés accompagnés de ses impacts et gravités	10
Atelier 2: Sources de risques	12
Atelier 3: Scénarios stratégiques	13
1- Évaluations des niveaux des menaces	13
2- Scénarios stratégiques	14
3- Evaluation des scénarios stratégiques	16
Atelier 4: Scénarios Opérationnels	18
1- Elaboration des scénarios opérationnels	18
2- Evaluation de la vraisemblance	19
3- Stratégie de Gestion de risques	20
4- Matrice de gestion de risque	23
CONCLUSION	24



INTRODUCTION

Mediscope est une plateforme d'imagerie médicale basée sur l'IA conçue pour analyser et traiter des données de santé sensibles : images DICOM, résultats d'inférence et informations patients. L'ensemble de ces données est hébergé dans un environnement certifié HDS, ce qui impose un niveau d'exigence élevé en matière de sécurité. Dans un contexte où les cyberattaques ciblant le secteur de la santé explosent cette analyse EBIOS Risk Manager permet d'identifier les risques numériques majeurs, d'évaluer leur criticité et de définir des mesures de traitement concrètes pour protéger les patients, les données et assurer la continuité du service Mediscope.

Atelier 1 : Socle de sécurité

1- Cartographie des valeurs métiers et Évaluation CID

VALEUR MÉTIER				BIENS SUPPORTS ASSOCIÉS			BESOINS DE SÉCURITÉ (0-3)		
Dénomination de la valeur métier	Nature	Description	Entité responsable	Biens supports associés	Description du bien support	Entité responsable	C	I	D
Mission 1 : Assistance au diagnostic par IA									
Diagnostic (Analyse IA)	Processus	Production de bilans automatisés (hypothèses diagnostiques, sévérité) à partir des images médicales DICOM. Constitue la valeur centrale de la plateforme.	Direction médicale / R&D IA (Interne)	Modèles IA entraînés	Réseaux de neurones pour détection hémorragie, pneumothorax, embolie, AVC	R&D IA (Interne)	3	3	3
				Pipeline d'inférence GPU	Infrastructure de calcul (autoscaling GPU, Kubernetes) pour exécution des modèles	Ops Cloud (Interne)	2	3	3

				Pipeline DICOM	Composant d'ingestion, pré-traitement et routage des images DICOM	R&D IA / Prod (Interne)	2	3	3
				Connecteurs PACS/RIS hospitaliers	Interfaces d'intégration avec les systèmes d'imagerie des établissements clients	Intégrateurs DICOM (Externe)	2	3	2
				Viewer web clinicien	Interface de lecture et validation des résultats IA par les radiologues/urgentistes	Produit (Interne)	3	2	3

Mission 2 : Gestion et protection des données de santé

Données médicales des patients	Information	Ensemble des données de santé à caractère personnel : images DICOM, résultats d'analyse IA, identités patients, historiques. Protégées par le RGPD, le secret médical et la certification HDS.	DPO / RSSI (Interne) — Hébergeur HDS (Externe)	Base de données patients (stockage images & résultats)	Stockage chiffré des images DICOM et des conclusions IA associées aux dossiers patients	Hébergeur HDS (Externe)	3	3	2
				Infrastructure HDS (hébergeur certifié)	Environnement d'hébergement agréé HDS pour données de santé ; datacenter multi-zones	Hébergeur HDS (Externe)	3	2	3
				Cloud GPU (MLOps)	Environnement cloud de calcul utilisé pour l'entraînement et l'inférence IA	Fournisseur cloud GPU (Externe)	2	3	3
				Portail patient	Interface d'accès aux résultats et comptes-rendus par les patients	Produit (Interne)	3	2	1

				Canaux de chiffrement / TLS	Protocoles de chiffrement des données en transit entre les composants	Ops Cloud / RSSI (Interne)	3	2	2
Mission 3 : Traçabilité et conformité réglementaire									
Traçabilité	Processus / Information	Enregistrement horodaté et inaltérable de l'ensemble des accès, décisions IA et actions cliniciennes. Obligatoire pour la conformité ISO 13485, RGPD et la défense en cas de mise en cause médico-légale.	RSSI / DPO / Direction médicale (Interne)	Journaux d'audit (logs)	Fichiers de logs applicatifs et systèmes enregistrant les accès et décisions IA	RSSI / Ops (Interne)	2	3	2
				Système d'observabilité (SIEM)	Plateforme de collecte, corrélation et analyse des événements de sécurité	RSSI (Interne) SI hospitalier (Externe, option avancée)	2	3	2
				Console d'administration	Tableau de bord de supervision des accès, utilisateurs et configurations	Ops / RSSI (Interne)	3	3	2
				Certificats ISO 13485 / HDS	Accréditations réglementaires conditionnant l'activité de dispositif médical	Organisme de certification (Externe)	1	3	1

Mission 4: Priorisation et aide à la décision clinique

Priorisation des patients	Processus	Service de triage automatisé qui classe les patients selon la sévérité estimée par l'IA, optimise les files d'attente et oriente les urgences. Critique en contexte hospitalier 24/7.	Direction médicale / Ops Cloud (Interne)	Moteur de priorisation IA	Module IA de scoring et classement des cas par sévérité et filière (urgences, horaires)	R&D IA (Interne)	1	3	3
				Infrastructure multi-zones / PRA	Déploiement redondant (multi-AZ), plan de reprise d'activité inter-zones	Ops Cloud (Interne)	1	2	3
				Tableaux de bord qualité (SLA)	Métriques de performance et de disponibilité du service d'urgences	Produit / Ops (Interne)	1	2	3
				Webhooks / API d'intégration SI	Interfaces d'intégration profonde avec les SI hospitaliers pour notifications en temps réel	DSI hospitalière (Externe) / Produit (Interne)	2	3	3

Mission 5: Modèle commercial et développement client									
La Vente (activité commerciale)	Processus	Processus de souscription des établissements (abonnement + usage IA), gestion des contrats, facturation et renouvellements. Génère la totalité du CA (11,9 M€ en 2024).	Direction commerciale / DPO (Interne)	CRM / Base clients contractuels	Système de gestion des comptes clients, contrats, SLA et données de facturation	Direction commerciale (Interne)	3	2	1
				Portail de facturation et abonnement	Plateforme de gestion des souscriptions, usage et paiements des établissements	Direction commerciale / Ops (Interne)	3	3	2
				Données financières et contrats	Ensemble des informations contractuelles, tarifs, et données financières stratégiques	Direction (Interne)	3	2	1
				Infrastructure SSO / Identité clients	Système d'authentification unique (SSO, MFA, RBAC/ABAC) pour les accès établissements	Ops / RSSI (Interne)	3	3	2

2- Événements redoutés accompagnés de ses impacts et gravités

VALEUR MÉTIER	ÉVÉNEMENT REDOUTÉ	IMPACTS	GRAVITÉ
Diagnostic	1. Corruption des données DICOM ou résultats IA	- Perte de confiance des cliniciens. - Non conformité ISO 13485	4
	2. Altération du moteur IA	- Résultat IA incohérents - Pertes de chance de guérisons pour les patients	5



Atelier 2: Sources de risques

La source de risque aborde un ensemble de points tels que l'identification des sources de risques, la définition des objectifs visés et les couples sources qui vous seront présentés dans le tableau ci-dessous.

Source des risques	Objectifs visés	Motivation	Ressource	Activité	Pertinence
Hacker solitaire	Provoquer une panne, altérer les résultats IA, casser la priorisation. et prouver qu'il peut compromettre un système.	Significatif	Modéré	Significatif	Moyenne
Hacktiviste	S'opposer à l'usage de l'IA, à la privatisation des données de santé, ou à la gestion hospitalière. Ils privilégient les actions visibles, symboliques et médiatiques	Important	significatif	important	Elevée
Employé vengeur	Agir par frustration pour nuire à l'entreprise.	Important	important	important	Elevée
concurrency	Chercher à obtenir un avantage stratégique, à ralentir Mediscope, et à récupérer des éléments technologiques clés.	important	important	important	Elevée

Groupe cyber	Cibler les systèmes de santé car ils sont critique et les entreprises sont toujours prêt à payer	Important	important	important	Elevée
--------------	--	-----------	-----------	-----------	--------

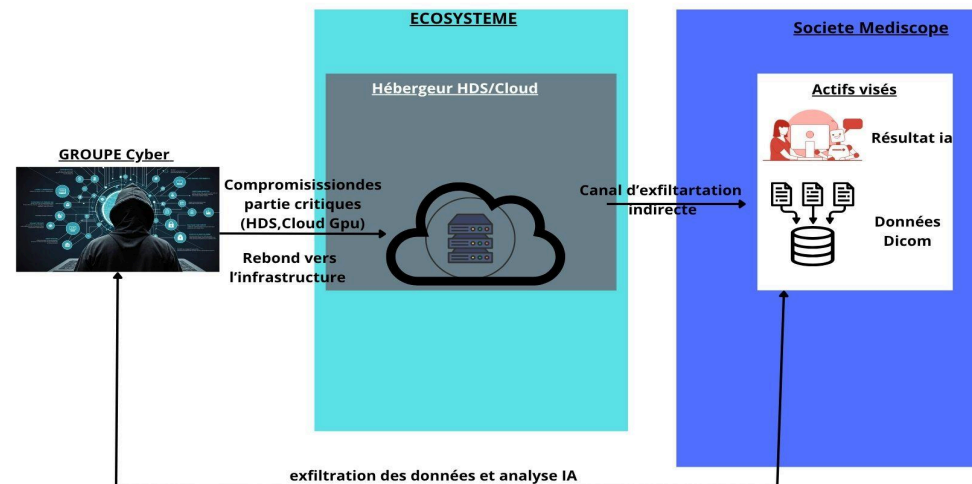
Atelier 3: Scénarios stratégiques

1- Évaluations des niveaux des menaces

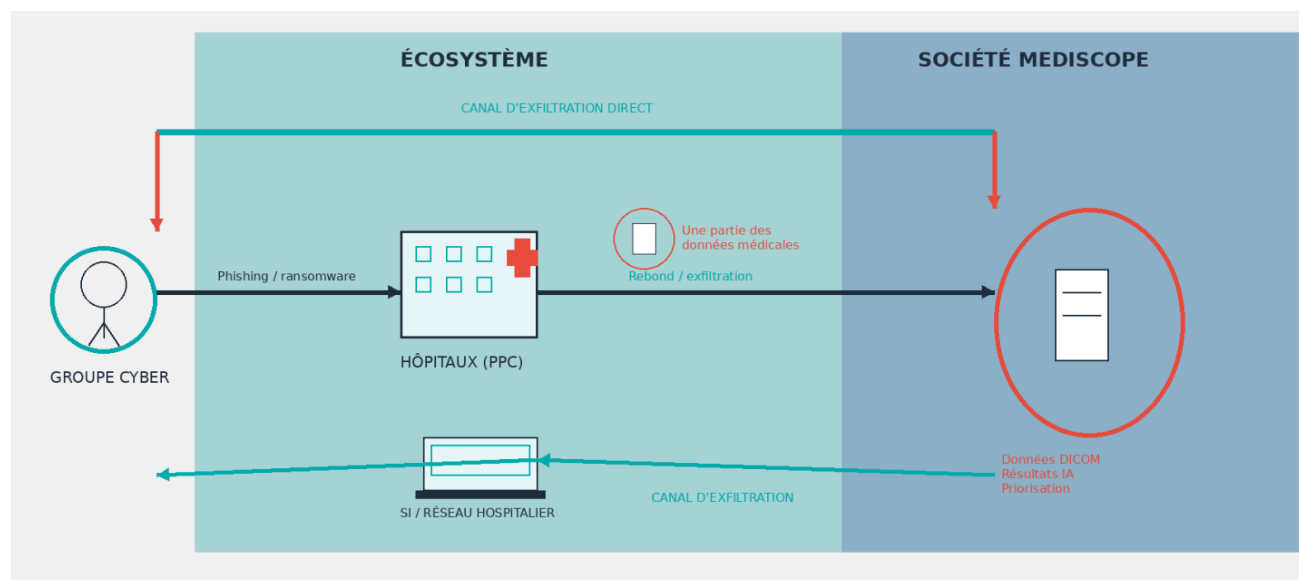
Partie prenante	Dépendance	Pénétration	Maturité	Confiance	Niveau de menace	Explication
Hébergeur	4	4	3	3	1,77	Risque présent mais globalement maîtrisé
Employé	4	4	3	2	2,66	Source de risques très important à prendre en compte.
Auditeur	2	1	3	3	0,2	Négligeable
Hôpitaux	4	3	2	4	1,5	Risque réel mais limité

2- Scénarios stratégiques

Groupe cyber



Les hôpitaux



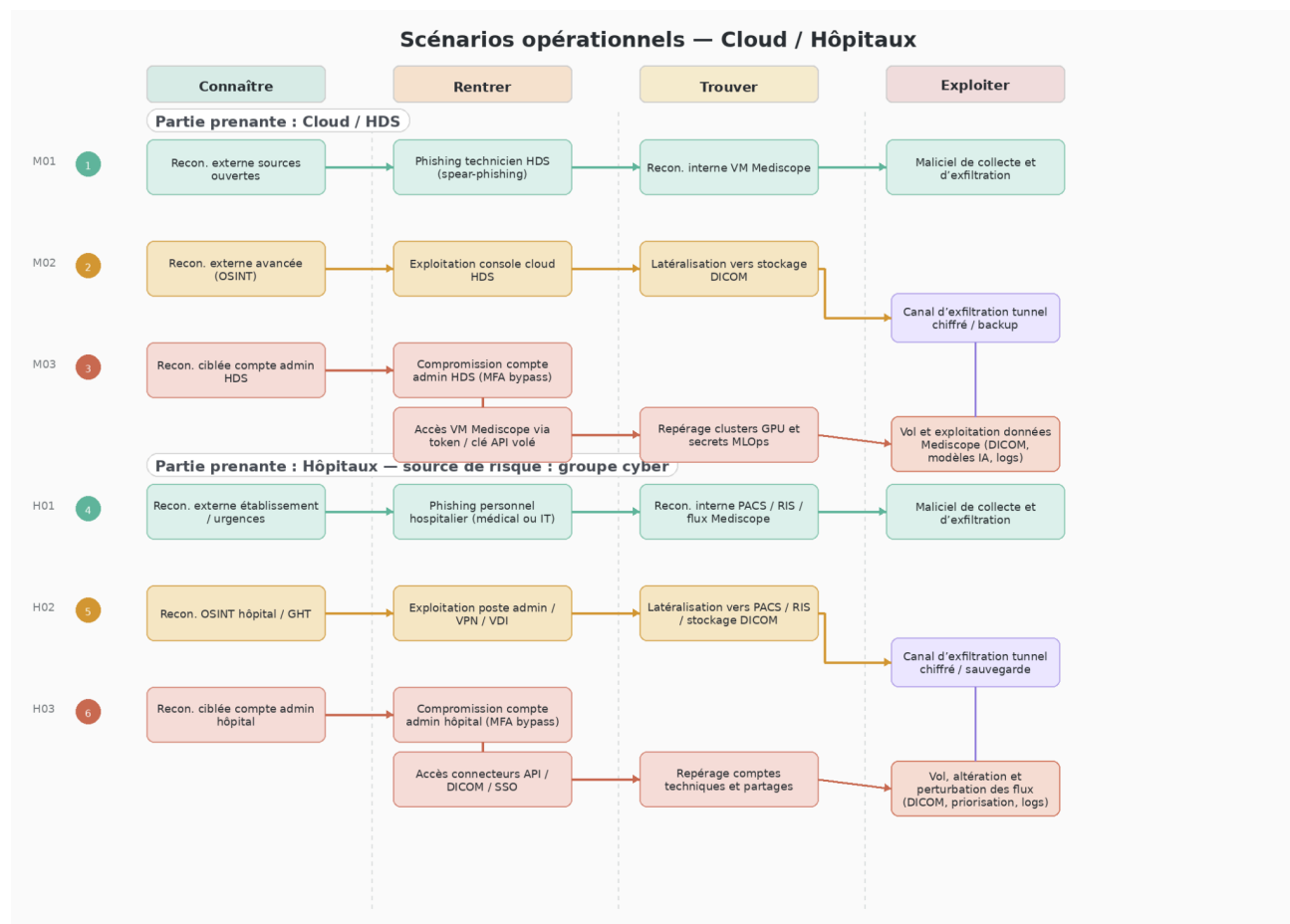
3- Evaluation des scénarios stratégiques

Source des risques	Objectifs visés	Chemins d'attaque stratégiques	Pertinence
Employé vengeur	Agir par frustration pour nuire à l'entreprise.	L'employé disposant d'accès internes abuse de ses privilèges pour modifier les paramètres du système, altérer les résultats IA ou perturber le service de priorisation des patients.	4
concurrence	Chercher à obtenir un avantage stratégique, à ralentir Mediscope, et à récupérer des éléments technologiques clés.	La concurrence exploite des failles applicatives ou humaines (phishing, ingénierie sociale) afin d'accéder aux systèmes internes	4

		et récupérer des informations sensibles (modèles IA, données techniques).	
Groupe cyber	Cibler les systèmes de santé car ils sont critique et les entreprises sont toujours prêt à payer	Le groupe cybercriminel compromet d'abord le SI d'un hôpital (phishing ou ransomware), puis exploite les connexions (API / DICOM) pour rebondir vers l'infrastructure Mediscope. Depuis cet accès, il cible les données DICOM et les résultats IA afin de les exfiltrer ou de rendre le service indisponible.	4

Atelier 4: Scénarios Opérationnels

1- Elaboration des scénarios opérationnels



2- Evaluation de la vraisemblance

CHEMINS D'ATTAQUE STRATÉGIQUES(ASSOCIÉS AUX SCÉNARIOS OPÉRATIONNELS)	VRAISEMBLANCE GLOBALE
Le groupe cyber vole les données Mediscope en compromettant l'hébergeur HDS, puis en créant un canal d'exfiltration indirect depuis le cloud	4: Quasi certain
Le groupe cyber rebondit depuis l'hébergeur HDS vers les VM Mediscope pour accéder aux stockages DICOM et aux résultats IA	3: Très vraisemblable
Le groupe cybercriminel exploite une faille cloud pour cartographier l'infrastructure Mediscope et identifier les clusters GPU et secrets MLOps	2: Vraisemblable
les cybers criminels détourne un canal de sauvegarde ou un tunnel chiffré pour exfiltrer des données Mediscope depuis l'environnement hospitalier	2:Vraisemblable
Un groupe cybercriminel altère les flux DICOM ou la priorisation IA depuis le réseau hospitalier pour perturber l'activité clinique	2: Vraisemblance

3- Stratégie de Gestion de risques

Scénarios de risque	Vraisemblance	Gravité	Niveau de risque	acceptabilité du risque	intitule de décisions et des actions
sc1- Le groupe cyber vole les données Mediscope en compromettant l'hébergeur HDS, puis en créant un canal d'exfiltration indirect depuis le cloud	V4 – Quasi certain	4	16- Élevé	Inacceptable	Renforcer immédiatement la sécurité de l'environnement HDS/cloud : MFA renforcé sur les comptes d'administration, bastion d'administration, rotation des secrets, supervision des flux sortants, détection d'exfiltration, audit des sauvegardes et revue des comptes à privilèges.
sc2- Le groupe cyber rebondit depuis l'hébergeur HDS vers les VM Mediscope pour	V4 – Quasi certain	4	16- Elevé	Inacceptable	Cloisonner plus fortement les VM Mediscope, les stockages DICOM et les composants

accéder aux stockages DICOM et aux résultats IA					MLOps ; durcir les VM, limiter les accès API/token, renforcer la journalisation et appliquer le principe du moindre privilège.
sc3- Le groupe cybercriminel exploite une faille cloud pour cartographier l'infrastructure Mediscope et identifier les clusters GPU et secrets MLOps	V2 – Vraisemblable	3	6-Moyen	Tolérable sous contrôle	Mettre en place un durcissement MLOps : coffre-fort à secrets, revue des rôles cloud, CSPM / contrôle de configuration, patch management, surveillance des appels API et inventaire continu des clusters GPU.
Sc4- Les cybercriminels détournent un canal de sauvegarde ou un tunnel chiffré pour exfiltrer des données Mediscope depuis l'environnement hospitalier	V2 – Vraisemblable	4	8- Moyen	Tolérable sous contrôle	Encadrer les tunnels et flux de sauvegarde, journaliser les transferts DICOM, détecter les volumes anormaux, revoir les accès distants, et imposer des clauses SSI / SLA de sécurité aux hôpitaux et à leurs infogéreurs.

Sc5- Un groupe cybercriminel altère les flux DICOM ou la priorisation IA depuis le réseau hospitalier pour perturber l'activité clinique	V2 – Vraisemblable	4	8- Élevé	Inacceptable	Renforcer l'intégrité des flux DICOM, superviser les règles de priorisation, segmenter les connecteurs hospitaliers, mettre des alertes sur les anomalies de flux, et imposer un mode dégradé / PRA avec validation humaine renforcée.
--	--------------------	---	----------	--------------	--

4- Matrice de gestion de risque

1	R5	R4		
2		R2	SC1 R1	SC2 R3
3			SC3	SC5
4			SC4	
GRAVITÉ	1	2	3	4
				VRAISEMBLANCE



CONCLUSION

L'analyse montre que la menace la plus critique pour Mediscope ne vient pas d'attaques directes mais de son écosystème en particulier de l'hébergeur HDS. Ce dernier représente aujourd'hui le maillon le plus exposé : s'il est compromis, l'attaquant obtient un accès quasi complet à l'infrastructure Mediscope.

Trois mesures doivent être appliquées sans délai : durcir les accès HDS (MFA robuste, bastion, rotation systématique des secrets), cloisonner strictement les VM et les stockages DICOM, et imposer des exigences de sécurité contractuelles à l'ensemble des prestataires.

Sans ces actions deux scénarios atteignent un niveau de risque inacceptable de 16, ce qui dans un contexte médical, peut avoir un impact direct sur la sécurité des patients et la continuité du service.